

## EVALUACIÓN DEL MÓDULO 9

---

---

Yosselinne Navarro

## Matriz del Modelo de Responsabilidad Compartida y Mapa de Riesgos Cloud

Representación arquitectónica del modelo de responsabilidad compartida adaptado a los entornos IaaS, PaaS y SaaS para la infraestructura de InnovaCloud. Se delimitan con precisión los límites operativos entre el proveedor cloud (CSP) y la organización, asignando al cliente el control estricto sobre los datos confidenciales de salud (PHI) y finanzas, la gestión de identidades (IAM), las políticas de cifrado y el bastionado de sistemas operativos en IaaS. Asimismo, se incorpora un panel de identificación de vectores de amenaza críticos en la nube, destacando la prevención contra fugas de información, secuestro de cuentas privilegiadas y configuraciones defectuosas en almacenes de objetos.

## Matriz de Cumplimiento Normativo (HIPAA, GDPR, ISO 27017) y Acuerdos de Nivel de Servicio

Formalización del marco regulatorio y contractual que sustenta la migración segura a la nube. Se desglosan las exigencias técnicas aplicables a plataformas digitales del sector salud y financiero: salvaguardas técnicas y firma de acuerdos BAA bajo la normativa HIPAA, garantías de soberanía y notificación de incidentes según el RGPD/GDPR, y adopción de controles de seguridad específicos para servicios cloud certificados bajo ISO/IEC 27017. En paralelo, se documentan las cláusulas de SLA simuladas que fijan un compromiso de disponibilidad mensual del 99.95%, penalizaciones por interrupción no programada y auditorías independientes anuales SOC 2 Tipo II.

## Captura: Fortificación de Aplicaciones Web, Cabeceras de Seguridad y Mitigación de Amenazas OWASP (CLI)

```
adminingen@ingen-server:~$  
adminingen@ingen-server:~$  
adminingen@ingen-server:~$  
adminingen@ingen-server:~$  
adminingen@ingen-server:~$  
adminingen@ingen-server:~$  
adminingen@ingen-server:~$  
adminingen@ingen-server:~$  
adminingen@ingen-server:~$  
adminingen@ingen-server:~$  
adminingen@ingen-server:~$ cat << 'EOF' > /tmp/waf_headers.conf  
# Directivas de Seguridad Web - InnovaCloud WAF  
Header always set Strict-Transport-Security "max-age=31536000; IncludeSubDomains; preload"  
Header always set X-Frame-Options "nosniff"  
Header always set X-Content-Type-Options "nosniff"  
Header always set Content-Security-Policy "default-src 'self'; script-src 'self'; frame-ancestors 'none';"  
Header always set X-XSS-Protection "1; mode=block"  
EOF  
adminingen@ingen-server:~$ cat << 'EOF' > /tmp/waf_sim.py  
import re  
payloads = [  
    'admin' OR '1'=  
    '<script>alert(/XSS_ATTACK/)</script>',  
    'SELECT * FROM pacientes WHERE id=102"  
    ]  
regex_sql = re.compile(r'(\b)(OR|UNION|SELECT|DROP|INSERT)\b', re.I)  
regex_xss = re.compile(r'<script.*?</script.*?>', re.I)  
print("=== SIMULADOR DE WAF CLOUD - INNOVACLOUD ===")  
for p in payloads:  
    if regex_sql.search(p) or regex_xss.search(p):  
        print(f"[BLOQUEADO - 403 FORBIDDEN] Payload malicioso detectado: {p}")  
    else:  
        print(f"[PERMITIDO] Entrada legítima: {p}")  
EOF  
adminingen@ingen-server:~$ python3 /tmp/waf_sim.py  
File "/tmp/waf_sim.py", line 11  
    if regex_sql.search(p) or regex_xss.search(p):  
IndentationError: expected an indented block after 'for' statement on line 10  
adminingen@ingen-server:~$
```

Validación técnica en consola de los mecanismos de protección en capa de aplicación (Capa 7) para servicios expuestos. Se evidencia la configuración de directivas HTTP avanzadas en el Web Application Firewall (WAF), incluyendo HSTS (Strict-Transport-Security), políticas restrictivas de orígenes (Content-Security-Policy), prevención de clickjacking (X-Frame-Options: DENY) y mitigación de sniffing de tipos MIME. Adicionalmente, la ejecución del motor de filtrado demuestra la inspección de entradas y el bloqueo automático en tiempo real con código 403 Forbidden ante intentos de inyección SQL (SQLi) y cross-site scripting (XSS).

### **Arquitectura de Identidad Federada, Autenticación Multifactor (MFA) y Control Basado en Roles**

Diagrama funcional del ecosistema de gestión de identidades y accesos (IAM) corporativo. Se detalla el flujo de autenticación centralizado mediante un proveedor de identidades (IdP) empresarial implementando federación de identidades mediante SAML 2.0 y OpenID Connect, complementado con la exigencia obligatoria de autenticación multifactor (MFA). A su vez, se plasma la asignación granular de privilegios bajo el modelo RBAC, segregando de forma estricta los perfiles médicos, operativos y administrativos, garantizando el principio de menor privilegio e integrando el registro inmutable de sesiones hacia repositorios de auditoría cloud.

### **Topología de Red Virtual Segura, Aislamiento por Subredes y Microsegmentación**

Diseño estructural de la Virtual Private Cloud (VPC) para el despliegue seguro de plataformas críticas. Se exhibe una arquitectura modular multi-capa protegida perimetralmente por un WAF/CDN, con una subred pública para el balanceador de carga (ALB) e Internet Gateway, y subredes privadas estrictamente aisladas para los servicios de cómputo y clústeres transaccionales de bases de datos. Se evidencia el uso de un NAT Gateway para el tráfico saliente seguro, junto con grupos de seguridad (*Security Groups*) y listas de control de acceso (NACL) que bloquean cualquier acceso directo desde el exterior hacia las bases de datos de pacientes.